Kiểm thử hồi quy an ninh khi hợp đồng công cụ thay đổi

Phòng thủ prompt injection gián tiếp cho LLM agent

Nguyễn Thùy Dương Đặng Ngọc Huy Vũ Hồng Quang

Nhóm 11 • Chính sách quản trị an ninh mạng

10 tháng 10 năm 2026

Vấn đề cần giải quyết

- Agent đọc nội dung không tin cậy rồi đề xuất lời gọi công cụ.
- Policy kiểm tra quyền; công cụ có thể sửa tệp, gửi thư hoặc tạo lịch.
- Khi contract đổi, policy cũ có thể hiểu sai hoặc từ chối tham số mới.

Câu hỏi: phòng thủ có giữ an toàn và hoàn thành nhiệm vụ sau migration?

Nền tảng cần phân biệt

Contract	Tên công cụ, schema, mặc định, scope và ý nghĩa tác động.
Guard	Quyết định ALLOW/DENY trước native dispatch.
Oracle	Chấm trạng thái sau thực thi, độc lập với verdict của guard.
Utility	Mức hoàn thành nhiệm vụ hợp lệ; chặn mọi thứ không đủ.

Nghiên cứu liên quan

- **AgentDojo**: môi trường stateful, đo security và utility.
- **InjecAgent**: đánh giá prompt injection gián tiếp.
- **CaMeL**: tách dữ liệu và luồng điều khiển, kiểm tra capability.
- **Progent**: kiểm soát đặc quyền qua policy.

Nhóm tập trung vào **đo hồi quy theo phiên bản**, không nhận guard là nguyên lý mới.

Thiết kế kiểm thử theo cặp

- Cố định task, carrier, model và trạng thái ban đầu.
- Thay contract $v0 \rightarrow v1$; giữ hoặc chuyển đổi policy.
- An ninh: quan sát harmful effect *H*; hồi quy là $0 \rightarrow 1$.
- Utility: quan sát *U*; suy giảm là $1 \rightarrow 0$.
- Giữ các bản ghi thiếu bằng chứng là `not_scored`.

Phần giải pháp TaskFileScope

- Nhiệm vụ: đọc và bổ sung hoạt động vào đúng file ID 3.
- Guard chỉ cấp quyền tìm tên tệp, đọc và append theo scope.
- $v0$: tham số `file_id`.
- $v1$: `resource = {space, file_id}`.
- F giữ decoder cũ; M chuyển decoder sang $v1$, giữ nguyên quyền.

Luồng thực thi và bằng chứng

1. Manifest khóa cấu hình và định danh nhiệm vụ.
2. Agent đề xuất lời gọi; guard kiểm tra trước executor.
3. Ghi policy, tham số, decision, dispatch và state trước/sau.
4. Chuẩn hóa trace rồi gọi oracle độc lập.
5. Validator kiểm tra bằng chứng; thiếu dữ liệu giữ nguyên trong mẫu.

Kết quả kiểm tra nguồn

Cấu hình	Contract	Decoder	Utility
F	$v0$	$v0$	Thành công
F	$v1$	$v0$	Không thành công
M	$v0$	$v0$	Thành công
M	$v1$	$v1$	Thành công

Chuỗi thao tác xác định qua ToolsExecutor và scorer upstream.
Không phải kết quả hành vi LLM thật.

Đánh giá tiếp theo và hạn chế

- Fake provider đã kiểm tra được đường chạy trong fresh child.
- Một task và migration tự thiết kế chưa đủ để suy rộng.
- Task không cấp quyền xóa: chưa bộc lộ harmful-effect contrast.
- Tiếp theo: hoàn thiện evidence binding, review, rồi chạy LLM thật.

Kết luận

- Đã xác định vấn đề khi hợp đồng công cụ thay đổi.
- Đã hiện thực guard theo task và migration policy cụ thể.
- Utility mất ở F/v1 và được giữ ở M/v1 trong kiểm tra nguồn.
- Hiệu quả trước prompt injection trên mô hình thật còn phải đánh giá.

Thảo luận: làm sao giữ quyền đúng khi cấu trúc tài nguyên thay đổi?